

Project 6: Mitigating Risk with a BIA, BCP, and DRP

Cole Dombrowski - MISY 5325

1. Planning Assumptions

This plan focuses on a Category 4 hurricane making direct landfall in the Sabine Coastal Health Network (SCHN) service area, causing severe flooding, wind damage, and regional power and telecommunications outages lasting up to 72 hours.

Assumptions:

- Power will be lost at all five SCHN facilities. Backup generators will provide limited power for up to 72 hours, but flooding may make it difficult to resupply fuel.
- Primary internet connections will go down, limiting normal access to the cloud-based EHR and Microsoft 365.
- Patient demand will remain high at SCHN's primary care facilities due to storm-related injuries, while telehealth services will be limited by local power outages.

2. Business Impact Analysis

Business Function	Importance	Major Resources/Systems	Impact of Unavailability	MAO	RTO	RPO	Priority
1. Emergency Patient Care	Critical for life safety and immediate trauma response	Core network, physical facility, EHR, downtime forms	Severe patient harm, liability, regulatory failure	2 Hours	1 Hour	N/A - Manual downtime documentation	1
2. EHR Access	Required for accurate diagnosis, charting, and medication delivery	Cloud EHR, network connectivity, workstations	Medical errors, delayed care, missing patient history	4 Hours	2 Hours	1 Hour	2
3. Telehealth Services	Continuity of care for 70,000 regional patients	Telehealth platform, M365, Internet	Disrupted remote monitoring	24 Hours	12 Hours	24 Hours	3
4. Billing & Claims	Sustains organizational cash flow	Billing software, M365 (Email)	Delayed revenue, backlog of administrative work	5 Days	3 Days	24 Hours	4

Reasoning: Priority is dictated by life safety. Emergency Patient Care and EHR access are immediately prioritized to prevent physical harm. Telehealth is highly valuable but secondary to acute physical care during a disaster. Billing can be deferred the longest without impacting patient survival. These recovery objectives reflect SCHN's limited resources while giving the shortest recovery times to functions where delays could directly affect patient safety.

3. Business Continuity Plan

Continuity of Critical Functions:

Emergency patient care and access to the EHR must be maintained. The Chief Medical Officer and IT Director will serve as the Continuity Managers.

Activation and Notification:

The plan will be activated if primary power or internet service is down for more than 30 minutes. The IT team will use a cellular SMS alert system to notify all 475 SCHN employees.

Alternate Operating Procedures:

- Patient Care: Clinical staff will switch to standardized paper forms for documenting patient care. Pre-printed downtime forms will be stored at all five facilities. If a facility becomes inaccessible because of flooding, patients will be redirected to another operational SCHN facility when capacity allows.
- Telehealth: Non-critical telehealth appointments will be rescheduled manually using cellular communication. Patients will be notified of changes through available phone or cellular communication methods.

- **Dependencies:** Continuity will depend on having enough diesel fuel for the backup generators and having enough staff available, since some employees may be unable to reach the facilities because of flooding.
- **Stakeholder Communication:** SCHN leadership will use available cellular or internet-based communication to provide status updates to employees, patients, and vendors.
- **Transition Back:** Once power and internet service are restored, clinical staff will enter the paper records into the EHR. The Continuity Manager will review the data for accuracy before normal operations resume.

4. Disaster Recovery Plan

The IT department's main priority is restoring network connectivity so staff can regain access to the cloud-based EHR and Microsoft 365. The network receives the first technology recovery priority because it is a dependency for restoring EHR access and supporting emergency patient care.

Activation and Sequence:

1. **Core Network (Priority 1):** IT Director activates backup cellular or satellite routers to establish a basic network connection.
2. **EHR / Microsoft 365 (Priority 2):** IT restores secure VPN or Zero Trust connections over the backup network so employees can safely access cloud systems.
3. **Data Restoration:** Since the EHR and Microsoft 365 are cloud-hosted, vendors are responsible for restoring the underlying cloud services and data. SCHN remains

responsible for restoring connectivity, user access, authentication, and locally stored downtime records.

4. **Validation:** IT staff will test the systems before allowing full staff access. This could include creating a test patient record and sending a test email to confirm that the EHR and Microsoft 365 are working properly.
5. **Return to Normal:** Once primary network services are restored, IT will transition users from the backup network to normal connectivity, verify system access, and confirm that all downtime records and queued transactions have been entered successfully.
6. **Dependencies:** Recovery depends on backup power, cellular or satellite connectivity, cloud service availability, and successful user authentication. SCHN must also reconcile paper downtime records with the EHR before normal operations are fully restored.

5. Recovery Priority and Tradeoff Decision

The Tradeoff: During the first 72 hours, SCHN will dedicate available generator power and backup network bandwidth to emergency patient care and EHR access. Billing, HR, and other administrative departments will temporarily lose power and network access.

Rationale: SCHN has limited backup power and network capacity, so these resources need to be focused on patient care and other life-safety needs rather than administrative operations.

Accepted Risk: SCHN accepts the possibility of a significant administrative backlog and temporary interruptions in cash flow while these departments are offline.

6. Testing and Maintenance

Testing Plan:

SCHN will conduct a tabletop exercise each year to simulate a hurricane causing a power and network outage. The IT Director, Chief Medical Officer, facility managers, and key clinical staff will participate. The exercise will focus on how quickly staff can switch to paper charting and how effective the SMS notification system is. The exercise should also evaluate the recovery sequence for backup connectivity, EHR/Microsoft 365 access, user authentication, and system validation.

Maintenance Triggers:

The BCP and DRP will be reviewed and updated annually, as well as after:

1. Major technology changes, such as switching to a new telehealth provider.
2. A real disaster or significant security incident, so lessons learned can be incorporated into the plans.

7. Connection to Previous Projects

The priorities in this BIA, BCP, and DRP are based on SCHN's existing operations, including 475 employees across five facilities serving approximately 70,000 patients. Earlier projects identified SCHN's reliance on cloud-based systems such as the EHR and Microsoft 365 as an important consideration. The recent M365 billing phishing incident also reinforced the need for secure authentication when accessing these systems through backup networks. Finally, putting billing recovery behind clinical operations reflects the earlier risk mitigation decisions and SCHN's limited resources.

References

- Gibson, D., & Igonor, A. (2020). *Managing Risk in Information Systems* (3rd ed.). Jones & Bartlett Learning.
- National Institute of Standards and Technology. (2010). *Contingency Planning Guide for Federal Information Systems* (NIST SP 800-34 Rev. 1). U.S. Department of Commerce.